LAB 5 - Şişeleme Hattı: SBOM / CVE / Patch

Çıktı: Zafiyet kararı (Vulnerability Decision); Evidence Pack EP 09, 10 ve 11 ile ilişkilidir.

Kavramlar

SBOM, yazılım malzeme listesidir. CVE, açığın kayıt numarasıdır. CVSS, açığın ciddiyetini 0–10 aralığında belirtir. Bir CVE'nin sistemi etkilemesi için üç koşul birlikte kontrol edilir: bileşenin bulunması, sürümün etkilenmesi ve açığın ulaşılabilir olması.

Verilen zafiyet kaydı

Alan	Föyde verilen bilgi
Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Kayıt föydeki örnek senaryodur; CVE-XXXX-XXXX gerçek bir zafiyet kimliği değildir.

Görev - Karar akışı

1. Bu CVE bizi gerçekten etkiliyor mu?

Henüz kesin olarak bilinmiyor; SBOM'da ilgili bileşenin bulunması, sürümünün CVE'den etkilenmesi ve açığın erişilebilir olması durumunda sistemimiz etkilenir.

2. Üretimi hemen durdurur musunuz? Neden?

Hemen durdurmam. Önce açığın oluşturduğu risk değerlendirilir; çalışan güvenliğini tehdit ediyorsa üretim durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Yama önce izole bir test ortamında denenir. PLC ve HMI üzerindeki etkileri kontrol edildikten sonra uygulanır.

4. Bu yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Yama emniyet fonksiyonlarını etkileyebilir. Acil durdurma ve Safety PLC test edilerek doğrulama ihtiyacı belirlenir.

5. Yama mümkün değilse telafi edici önlem ne olur?

Etkilenen sistem ağ üzerinden izole edilir, gereksiz bağlantılar kapatılır ve erişim yetkileri sınırlandırılır. Güvenlik duvarı kuralları sıkılaştırılarak sistem izlenir ve risk azaltılır.

Kaynaklar

• INSPECCO × KRIPTARIUM, Genel LAB Föyleri: LAB 5, PDF s. 6.